ShopNest: GDPR Data Governance & Classification Audit

Portfolio project by Priti More | Fictional company; all data is illustrative

1. Executive Summary

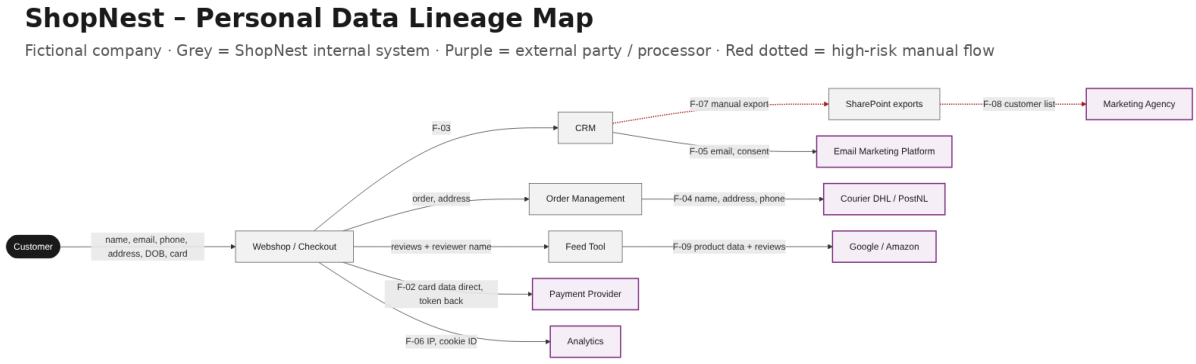
This audit reviewed how ShopNest, a fictional EU-facing online retailer with about 2 million customers, collects, uses, shares, secures and deletes personal data. It mapped 13 personal data elements, 9 data flows and 10 processing activities, and reviewed access for 8 roles and retention for 10 data types.

The audit found 9 issues: 4 High, 4 Medium and 1 Low. The most serious are uncontrolled manual exports of customer data, excess and orphaned access, and data kept with no deletion rule.

2. Scope & Method

- In scope: webshop, CRM, order management, payment provider, email marketing, courier integration, feed tool and SharePoint.
- Out of scope: physical security, network infrastructure and employee HR data.
- Method: data inventory → lineage mapping → Article 30 register → lawful basis review → RBAC design and access review → retention review → data subject rights and breach process review.

3. Data Lineage



Grey boxes are internal systems; purple boxes are external parties. Red dotted lines (F-07, F-08) are the highest-risk flows: manual exports shared outside the company.

4. Key Findings & Recommendations

ID	Finding	Risk	Recommendation
F1	Manual CRM exports on SharePoint, shared with agency by link	High	Controlled integration; Confidential label; DLP on external sharing; 30-day auto-delete
F2	Excess privilege, privilege creep, orphaned contractor account	High	Remove excess access; JML process; quarterly access reviews
F3	Customer data, CS notes, invoices and logs kept forever	High	Retention schedule with automatic deletion (Purview retention)
F4	Global admin account used for daily work	High	Separate admin accounts, MFA, Privileged Identity Management
F5	Erasure requests don't reach processors or old exports	Medium	DSR system checklist; notify processors; CRM restriction flag
F6	US email and analytics vendors: transfer safeguards unconfirmed	Medium	Confirm DPF certification or SCCs; update DPAs
F7	Full date of birth collected for age checks	Medium	Over-18 confirmation instead; delete stored DOB
F8	CS free-text notes may contain health information	Medium	Agent guidance; Purview scan for sensitive terms

F9	No Legitimate Interest Assessment for fraud prevention	Low	Write and approve LIA

5. Positive Observations

- Card payments go directly to the payment provider; ShopNest stores only a token (reduces breach impact and PCI DSS scope).
- Marketing emails use consent with an unsubscribe option.
- Order processing relies on the correct lawful basis (contract).

6. Priority Roadmap

- 30 days: fix exports (F1), access (F2) and admin accounts (F4).
- 60 days: data subject rights process (F5), transfer safeguards (F6), CS notes (F8).
- 90 days: automated retention (F3), date of birth minimisation (F7), LIA (F9).

7. Supporting Workbook

ShopNest_GDPR_Audit.xlsx contains the scope, findings register, data inventory, data flows, Article 30 register, lawful basis reference, RBAC matrix, access review, retention schedule, data subject rights workflow and breach workflow.